Вибір методів і засобів забезпечення необхідного рівня ІБ

Принципи побудови системи захисту:

1. Простота та інтуїтивна зрозумілість для рядового користувача функцій захисту, які він використовує.
2. Постійність захисту. На момент відмови системи захисту використовування функцій автоматизованої системи має бути заборонене.
3. Неперервність захисту. Захист інформації – це неперервний процес, який розпочинається на етапі проектування системи захисту, продовжується на етапі розробки та запуска в дію, а також на етапі супроводу системи захисту інформації. Паралельно із технічними та програмними засобами захисту мають неперервно діяти організаційні заходи захисту.
4. Всебічний контроль. Має бути змога перевірити права кожного суб’єкта по відношенню до кожного об’єкта, дії мають реєструватись, система має бути постійно спостереженою.
5. Відкритість проектування. Проект системи захисту не є таємницею (на відміну від таємних складових- ключів, паролів тощо). Механізми, які використовуються, та криптографічні алгоритми мають бути прозороми та дозволяти можливість їхньої перевірки та тестування.
6. Ідентифікація та розділення повноважень. Об’єкти та суб’єкти інформаційної системи повинні мати власні унікальні ідентифікатори, мають бути привласнені повноваження та рівні секретності. А також мають бути втілені механізми доступу відповідно до обраної в політиці безпеки моделлю доступу. Гість системи має одержувати мінімальний комплект повноважень, необхідних для виконання елементарних дій. Так само і неперевірені програми мають запускатись із мінімальними правами. Цей принцип тісно пов'язаний із наступним.
7. Контроль доступа. Контроль доступа може бути реалізований різними способами, серед них є варіанти використання фізичних параметрів користувача (сітківка ока, відбиток пальця тощо), однак ці способи обовязково мають доповнюватись іншими видами контролю: пін-кодами, паролями чи іншою таємною інформацією.
8. Надійність. Мають використовуватись перевірені та надійні засоби захисту, мають бути передбачені механізми тестування функцій системи безпеки та контроль за правильністю її роботи.
9. Функції захисту мають бути максимально відокремлені від функцій системи. Однак це не значить, що використовувати вбудовані штатні засоби захисту не можна. Мається на увазі, що функції захисту мають бути достатньо автономними в такій степені, щоби помилки та збої у функціональному програмному забезпеченні не призводили до відмови та помилок системи захисту інформації.
10. Захист памяті. Пакет програм, які виконують захист інформаційної системи, по можливості повинен розміщуватись в захищеній ділянці

памяті ОС, щоби забезпечити системний захист втручання ззовні. Якщо це неможливо, мають бути передбачені інші механізми захисту ПЗ, яке виконує задачі безпеки. Всі спроби проникнути до захищеної ділянки мають фіксуватись.

11. Реєстрація та журналювання. Всі події безпеки повинні реєструватись та зберігатись в журналах безпеки для забезпечення можливості розслідування інцидентів. Журнали безпеки повинні також захищатись від спроб НСД. Також мають бути передбачені утиліти, які сприяють ефективній обробці зареєстрованих подій, відсіюванню менш важливих та сигналізації про більш важливі. Адміністратор безпеки повинен мати змогу бути оповіщеним про спроби порушень.
12. Механізми захисту. Механізми захисту мають бути спрямовані на захист: конфіденційності, цілісності, доступності та спостереженості інформації. Додатково в сучасних реаліях слід мати також і засоби захисту від навязування інформації. Ці засоби є профілактичними, адже спам та реклама можуть містити потенційно небезпечні блоки та вкладення. Окремо слід згадати також засоби унеможливлення відмови від авторства, які непрямо сприяють захисту вищезазначених властивостей інформації.
13. Можливість нарощення та модифікації системи захисту. Система повинна по можливості мати модульну структуру, причому заміна одного модуля не повинна приводити до припинення роботи інших. Апгрейди та поновлення системи безпеки повинні відбуватись регулярно згідно запланованого графіка поновлень.
14. Гнучкість та зручність системи захисту. Мається на увазі, що система захисту не повинна погіршувати функціонування автоматизованої інформаційної системи, для якої вона спроєктована, мати можливість змінюватись у випадку змін в складі інформаційної системи.
15. Комплексність захисту. Передбачається, що в системі захисту можуть використовуватись взаємодоповнюючі програми, програми різних розробників, які виконують одні й ті самі функції, але дещо різним чином, і цим самим покращують можливість виявлення загроз та їх ліквідації. Це прямо стосується антивірусного забезпечення, щодо якого рекомендується використовувати АВЗ принаймні двох різних фірм-розробників.
16. Адекватність та сбалансованість системи захисту. Звичайно, добре мати захист для всіх непередбачуваних випадків та загроз. Однак, ризики в системі визначаються не лише імовірністю здійснення небажаної події, а й величиною потенційних збитків від цієї події. Отже, слід враховувати доцільність захисту від небажаних подій, збитки від яких будуть незначними. Система має бути не лише ефективною в сенсі захисту, а й в комерційному плані вигідною для користувача.
17. Порушення співробітників, що виокристовують інформаційну систему, повинні фіксуватись системою захисту, і за порушення повинні бути

визначені покарання – адміністративні та фінансові, згідно із внутрішніми положеннями організації, яка використовує систему захисту.

18. Спеціалізація та професіоналізм розробників та користувачів системи захисту. Розробка систем захисту інформації має відбуватись лише кваліфікованими спеціалістами, увесь персонал, який буде користуватись у подальшому системою захисту, повинен пройти навчання та підвищення кваліфікації, та володіти основними поняттями та принципами безпеки інформації. Супровід та обслуговування системи захисту мають бути виконані розробниками – спеціалістами в галузі захисту, а також спеціально призначеною Службою захисту інформації.

Основні правила, які слід враховувати при побудові та впровадженні системи захисту інформації.

- Забезпечення безпеки є неперервним процесом, який не повинен зупинятись чи зазнавати відмов.
- Безпека інформації може бути досягнута лише при комплексному застосуванні засобів та заходів захисту.
- Система захисту не забезпечить належний захист даних при недостатній підготовці обслуговуючого персоналу (адміністраторів) та користувачів.
- Ніяка система захисту не може вважатись абсолютно надійною.

Рівні захисту:

- Рівень захисту від НСД (ідентифікація-автентифікація, шифрування, керування доступом, контроль справжності інформації, знищення залишкових даних, антивірусний захист (АВЗ));
- Рівень захисту від несанкціонованого використання (квотування, контроль складу засобів, захист програм від дослідження, модифікації, несанкціонованого запуску);
- Рівень захисту від некоректного використання (ізоляція ділянок памяті, підтримка цілісності та несуперечності даних, попередження користувача не виконувати небезпечні дії);
- Рівень внесення інформаційної та функціональної надлишковості (тестування, самотестування, резервування, відновлення, самовідновлення, архівування, дублювання компонентів).

Виділяють такі підсистеми КСЗІ:

- Підсистема адміністрування безпеки;
- Підсистема керування доступом;
- Підсистема ідентифікації-автентифікації;
- Підсистема забезпечення цілісності (взаємодпоєднана із ПсАЗ)
- Криптографічна підсистема;
- Підсистема антивірусного захисту (ПсАЗ);

- Підсистема реєстрації та аудиту.

Зупинимось на функціях, які мають виконувати такі підсистеми:
Підсистема керування доступом:

1. Ідентифікація й автентифікація суб'єктів
2. Автентифікація об'єктів
3. Керування доступом суб'єкта до об'єкта

Підсистема реєстрації й обліку:

1. Реєстрація й облік подій у системі
2. Реєстрація дій адміністратора
3. Організація допомоги в синхронізації подій

Підсистема забезпечення цілісності:

1. Контроль цілісності всіх інформаційних ресурсів
2. Сигналізація про порушення цілісності і надання засобів для відновлення засобів системи захисту від НСД

Криптографічна підсистема:

1. Шифрування-дешифрування
2. Хешування
3. Генерація ключів

Згідно [Новіков, Грайворонський] можна навести такі механізми захисту на рівнях ІС:

Рівні захисту	Рівні інформаційної системи			
	Мережеві послуги	**ОС**	**СКБД**	**Застосування**
1. Захист від НСД до ресурсів системи	Ідентифікація мережевих пристроїв за IP та MAC адресами. Ідентифікація співтовариства SNMP. Автентифікація користувачів (протоколи EAPOL, RADIUS). Сегментація мережі. Віртуальні локальні мережі (VLAN). Міжмережеве екранування (брандмауери). Керування маршрутом пакетів. Шифрування трафіку. Віртуальні приватні мережі (VPN).	Ідентифікація й автентифікація користувачів. Автентифікація об'єктів доступу. Керування доступом користувачів до об'єктів. Шифрування даних автентифікації. Шифрування журналів реєстрації. Очищення ділянок оперативної пам'яті, що звільняються. Очищення дискового простору, що звільняється.	Ідентифікація й автентифікація користувачів. Керування доступом до таблиць, записів, процедур. Знищення залишкових даних.	Ідентифікація й автентифікація користувачів. Керування доступом до інтерфейсів, програмних модулів, даних. Шифрування даних. Накладання і перевірка ЕЦП. Захист від комп'ютерних вірусів – антивірусне ПЗ.

Рівні захисту	Рівні інформаційної системи			
	Мережеві послуги	**ОС**	**СКБД**	**Застосування**
2. Захист від несанкціонованого використання ресурсів системи	Контроль за виділенням ресурсів окремим інформаційним потокам. Якість обслуговування (QoS). Контроль за складом апаратних і програмних засобів мережі. Апаратна реалізація функцій, захист від дослідження і модифікації.	Планування процесорного часу. Контроль за виділенням оперативної пам'яті. Квоти на використання дискового простору. Контроль цілісності компонент ОС. Захист від відлагодження програм.	Контроль за виділенням ресурсів СКБД, квоти. Контроль за складом збережених процедур. Контроль доступу до використання збережених процедур.	Контроль за виділенням ресурсів. Контроль за складом програмних засобів ІС. Захист програм від копіювання, дослідження, модифікації. Контроль доступу до запуску програм та/або окремих процедур на виконання.
3. Захист від некоректного використання ресурсів системи	Сегментація мережі. Контроль цілісності пакетів (CRC). Контроль послідовності пакетів. Протокол STP. Віртуальні локальні мережі (VLAN).	Ізолювання ділянок оперативної пам'яті. Підтримка цілісності і несуперечності технологічної інформації (файлова система, системний реєстр, тощо). Попередження користувача перед виконанням небезпечних дій.	Підтримка цілісності і несуперечності даних. Попередження користувача перед виконанням небезпечних дій.	Підтримка власного домену виконання. Контроль цілісності, несуперечності і коректності даних. Попередження користувача перед виконанням небезпечних дій.

Рівні захисту	Рівні інформаційної системи			
	Мережеві послуги	**ОС**	**СКБД**	**Застосування**
4. Рівень внесення інформаційної й функціональної надлишковості	Тестування і самотестування обладнання. Відновлення і самовідновлення обладнання. Відновлення і самовідновлення ПЗ (завантаження з централізованого сервера). Централізоване резервування і відновлення (самовідновлення) конфігураційної інформації. Резервування каналів зв'язку (STP, VRRP).	Резервування інформації на рівні файлової системи і обладнання (RAID). Тестування і самотестування обладнання і системних програмних засобів. Відновлення і самовідновлення операційного середовища. Дублювання окремих пристроїв. Дублювання серверів.	Резервування інформації на рівні СКБД. Дзеркалювання. Створення резервних копій. Тестування і самотестування цілісності даних. Відновлення і самовідновлення даних з резервних копій. Розподілені БД.	Резервування інформації на прикладному рівні. Тестування і самотестування ПЗ. Відновлення і самовідновлення ПЗ. Дублювання програмних компонент

Вибір компонентів захисту інформації здійснюється з урахуванням багатьох факторів. Один із таких факторів має враховувати імовірності зникнення загроз при впровадженні компонентів захисту.

Імовірність зникнення i -ї загрози при проектуванні j -го компонента захисту інформації:

$p_{ij}^{зник} = f_i(x_{j1},...,x_{jm})$, де x_{jk} - ступінь виконання k -ї вимоги до j -го компонента захисту інформації.

Наприклад, $p_{ij}^{зник} = \dfrac{x_{j1}+,...+x_{jm}}{m}$, $x_{jk} < 1$.

При застосуванні j -го компонента ризик зменшується на величину Δ_j^i. Причому нам слід досягти $\sum_i \sum_j \Delta_j^i \to \max$. Тут величина

$\Delta_j^i = F(p_{ij}^{зник})$, загрози нумерують індексом $i = 1...n$, засоби захисту нумерують $j = 1...m$.

Інший фактор має враховувати вартість впровадження та підтримки засобів захисту, однак низька вартість не повинна негативно позначатись на якості системи захисту.

Вартість $i-$ го компонента захисту інформації позначимо c_i , зазвичай є обмеження на суму загальних витрат.

<u>Розв'яжемо задачу пошуку компромісу</u> між вартістю системи захисту та її ефективністю.

Є n компонентів захисту, кожен із яких у певному ступені реалізує визначені m вимог захисту.

Нехай c_{ik} - вартість $i-$го виду процеса, який має місце при впровадженні, підтримці чи реалізації $k-$го компонента, x_k $-$кількість компонентів $k-$го виду. Є обмеження на загальну суму витрат по кожному процесу:

$$\sum_k c_{ik} x_k \le c_j^{\max} \qquad (2.1).$$

<u>Приклади процесів:</u> встановлення, модифікація, аналіз журналів, резервування даних і т.і.(для програмних засобів), монтаж, профілактичний огляд і т.і. (для програмно-апаратних).

Матриця вартості реалізації процесів для кожного із компонентів системи захисту має вид:

$$C = \begin{pmatrix} c_{11} & \dots & c_{1n} \\ \dots & \dots & \dots \\ c_{n1} & \dots & c_{nn} \end{pmatrix}.$$

При цьому потрібно максимізувати функцію:

$$s_1 x_1 + s_2 x_2 + \dots + s_n x_n \to \max \quad (2.2),$$

де s_i – коефіцієнти внеску в захищеність системи $i-$ м компонентом захисту.

Цей підхід може використовуватись на доданок до інших методів визначення складу та кількості засобів захисту в інформаційних системах складної структури та великою кількістю резервних елементів.

<u>Примітка</u>

В даній постановці припускається, що засоби захисту виконують реалізацію однакових вимог захисту. Наприклад, це може бути ряд міжмережевих екранів, які розташовуються у різних ділянках мережі, одні з яких є більш важливими з точки зору захисту інформаційних ресурсів, інші – менш важливими; або програмні продукти зі схожим функціоналом, але різних фірм розробників.

<u>Метод Сааті</u>. Використовується для експертного визначення вагів (які показують важливість, чи то ефективність одного варіанту понад іншими). Сааті запропонував використовувати шкалу порівняння показників:

1- рівна важливість варіантів;
3- помірна перевага одного варіанту над іншим;
5- суттєва перевага одного варіанту над іншим;
7- значна перевага одного варіанту над іншим;
9- дуже сильна перевага одного варіанту над іншим.

В принципі можна дозволити використовувати будь-які співвідношення типу «в N разів більше». Експерти попарно порівнюють показники (наприклад, варіанти програмного забезпечення, чи певні апаратні складові, чи властивості системи, які повинні бути забезпечені). Результат записується до таблиці.

Прості дроби в клітинках трактуються так: якщо на перетині рядків «показник 1» та «показник 2» записано дріб 3/1, то це значить, що на думку експерта, показник №1 у 3 рази важливіший за показник №2.

Спосіб 1.

Далі прості дроби переводяться в десяткові та підраховуються суми по рядках, суми нормуються, і , таким чином, одержуються ваги кожного із показників w_i.

$$w_i = \text{Sum}\ (j=1..n)\ aij / \text{Sum}\ (i=1..n,\ j=1..n) a_{ij}$$

де a_{ij} – елементи матриці попарних порівнянь Сааті.

Для обчислень можна використовувати й середнє геометричне.

Приклад. Заповнена таблиця для показників «Вартість» (В), «Зниження продуктивності ІС за рахунок застосування системи захисту інформації» (П), «Захищеність» (З), «Обсяги ресурсів» (О) може мати вид:

Показник	В	П	З	О	Сума по рядку	Вага
В	1/1	3	1	8	13	0,42
П	1/3	1/1	1/3	3/1	4,66	0,15
З	1/1	3/1	1/1	7/1	12	0,38
О	1/8	1/3	1/7	1/1	1,6	0,05
				Всього:	31,26	1,00

Спосіб 2. Розв'язується задача знаходження власних значень матриці Сааті:

$(A-\lambda I)x = 0$. Ця система має нетривіальний розвязок тоді, й тільки тоді, коли визначник матриці

det(A-λI)=0.

Знаходимо корені характеристичного рівняння, вибираємо максимальний із них (за модулем) - і знаходимо відповідний йому вектор x. Нормуємо його, і одержані координати цього вектора й будуть ваговими коефіцієнтами кожного із показників. Недолік цього способу – значна трудомісткість.

Метод вибору оптимального варіанту реалізації системи захисту інформації

Найбільш загальна модель процеса захисту інформації може бути представлена описово таким чином: зловмисник за допомогою деякого джерела загроз генерує сукупність загроз (*n* загроз). Кожна *i*-та загроза характеризується імовірністю появи $\mathrm{P}_{\mathrm{i\ загр}}$ та збитками $\Delta q_i^{\text{загр}}$, які наносяться інформаційній системі. КСЗІ повністю або частково компенсує загрози для ІС. Якість цієї компенсації характеризується імовірністю усунення кожної *i*-ї загрози $\mathrm{P}_{\mathrm{i\ загр}}^{\text{ус}}$. За рахунок функціонування КСЗІ спостерігається сукупне зменшення збитків W, які наносяться ІС при реалізації загроз. Нехай відвернений збиток від *i*-ї загрози w_i.

Тоді задача синтеза системи захисту інформації формулюється так:

- Необхідно обрати той варіант реалізації системи захисту, за якого спостерігається максимум відвернених збитків від дії загроз при припустимих затратах на реалізацію системи захисту.

Розглянемо детальніше цю задачу. Попереджений збиток від реалізації *i*-ї загрози знаходиться як

$$w_i = \mathrm{P}_{\mathrm{i\ загр}} \Delta q_i^{\text{загр}} \mathrm{P}_{\mathrm{i\ загр}}^{\text{ус}},\ i = 1..n. \quad (1)$$

За умови незалежності загроз, і, відповідно, незалежності наслідків одержуємо:

$$W = \sum_{i=1}^{n} \Delta q_i^{\text{загр}} \mathrm{P}_{\mathrm{i\ загр}}^{\text{ус}} \mathrm{P}_{\mathrm{i\ загр}}. \quad (2)$$

Імовірність появи і-ї загрози одержується статистично, і відповідає відносній частоті її появи:

$\mathrm{P}_{\mathrm{i\ загр}} = \frac{\alpha_i}{\sum_{i=1}^{n} \alpha_i} = \bar{\alpha}_i$, де α_i – частота появи *i*-ї загрози.

Збиток, який наноситься *i*-ю загрозою, може визначатись в абсолютних одиницях – економічних втратах (при загрозах конфіденційності та інших), втратах часу (при загрозах доступності), обсягах втраченої та зіпсованої інформації (при загрозах цілісності). Однак, на етапі проектування КСЗІ визначити такі збитки складно. Тому використовують відносні збитки, які виражають ступінь небезпечності *i*-ї загрози для системи. Ступінь небезпечності визначається експертним

шляхом. При цьому припускається, що всі загрози для ІС становлять повну групу подій, тобто

$$\sum_{i=1}^{n} \Delta q_i = 1, \quad 0 \le \Delta q_i \le 1.$$

Для визначення імовірності усунення і-ї загрози $\mathrm{P}^{\text{ус}}_{\text{і загр}}$ зробимо припущення, що ця імовірність визначається тим, наскільки повно враховані якісні та кількісні вимоги до КСЗІ при проектуванні. Тобто

$$\mathrm{P}^{\text{ус}}_{\text{і загр}} = f(x_{i1} x_{i2} \dots . x_{im}), \qquad (3)$$

де x_{ij}- ступінь виконання j-ї вимоги для усунення і-ї загрози. Нехай перші k вимог будуть кількісними (j=1..k), а інші m-k – якісними (j=k+1..m). Ступінь виконання j-ї кількісної вимоги визначається її близькістю до оптимального значення, яке вимагається постановкою задачі. Для оцінки ступеня виконання *j*-ї кількісної вимоги використовують нормоване значення:

$$\bar{x}_{ij} = \frac{x_{ij} - x_{ij}^{\text{нг}}}{x_{ij}^{\text{нк}} - x_{ij}^{\text{нг}}}, \qquad (4)$$

де x_{ij} - поточне значення j- ї вимоги, $x_{ij}^{\text{нк}}$- найкраще значення, $x_{ij}^{\text{нг}}$- найгірше значення.

Розкладаючи (3.3) в ряд та обмежуючись першими членами, одержуємо:

$$\mathrm{P}^{\text{ус}}_{\text{і загр}} = \mathrm{P}^{\text{ус}}_{\text{і загр}}(0) + \sum_{i=1}^{m} \frac{\partial \mathrm{P}^{\text{ус}}_{\text{і загр}}}{\partial x_{ij}} x_{ij}, \quad (5)$$

де $\mathrm{P}^{\text{ус}}_{\text{і загр}}(0) = 0$ – імовірність усунення і-ї загрози при невиконанні вимог до КСЗІ,

$$\frac{\partial \mathrm{P}^{\text{ус}}_{\text{і загр}}}{\partial x_{ij}} = \beta_{ij}$$

величина, яка характеризує ступінь впливу вимоги на імовірність усунення і-ї загрози. При цьому

$$0 \le \beta_{ij} \le 1, \sum_{j=1}^{m} \beta_{ij} = 1.$$

Після підстановки до (5) одержуємо

$$\mathrm{P}^{\text{ус}}_{\text{і загр}} = \sum_{j=1}^{k} \beta_{ij} \bar{x}_{ij} + \sum_{j=k+1}^{m} \beta_{ij} \mu(x_{ij}).$$

Тоді остаточно одержуємо **значення загального попередженого збитку**

$$W = \sum_{i=1}^{n} \sum_{j=1}^{k} \bar{\alpha}_i \Delta q_i \, \beta_{ij} \, \bar{x}_{ij} + \sum_{i=1}^{n} \sum_{j=k+1}^{m} \bar{\alpha}_i \Delta q_i \, \beta_{ij} \, \mu(x_{ij}) \quad (6).$$

Тоді задача синтезу СЗІ зводиться до оптимального знаходження кількісних та якісних вимог до СЗІ при допустимих витратах:

Знайти $\max W(x_{ij}), i = 1..n, j = 1..m$ при обмеженнях виду $\mathrm{C}(x_{ij}) \le C_{\text{доп}}$.

Тобто, ми обчислюємо попереджений збиток для кількох варіантів реалізації системи захисту інформації (СЗІ), і обираємо той варіант, за якого попереджений збиток є максимальним.